PROPERTY TOKEN · PAKISTAN



Development Lifecycle

From legal foundation to production operations: phases, gates, standards and current status.

Version 1.0
Updated 10 October 2026
Repository: github.com/imgrasooldev/tokenize-property
Classification: Internal

Contents

1. About this document
2. Lifecycle at a glance
3. Guiding principles
4. Phases 0–8 in detail
5. Development flow (Steps 1–7)
6. Smart-contract lifecycle
7. Engineering workflow
8. Security standards by step
9. What gets built
10. Team and roles
11. Findings and top risks
12. Operations cadence
13. Open decisions and next actions

Appendix: Glossary

> **Current position (10 October 2026):** Phases 1 and 2 are complete. Phase 3 is in progress: Steps 1–4 are done internally: smart contracts (121 tests, 100% coverage) and a 4-validator Besu network where the full lifecycle runs on real blocks (50/50 checks). Step 5 (backend) is under way: the foundation is done, the ledger is next. Nothing has been externally audited yet.

1. About this document

Purpose, audience and how to read the status markers.

This document describes the complete lifecycle of the Property Token platform: a permissioned system for fractional ownership of real estate in Pakistan. An independent trustee holds each property; investors hold ERC-3643 security tokens that mirror the trustee's register; rent and investments move in PKR through banks. Smart contracts record ownership and entitlements only and never hold money.

It is written for the founders, the engineering team, the trustee, auditors and the regulator. It complements, and does not replace, the detailed documents in the repository: the contract specification, threat model, security standards baseline, product map and findings.

Status markers used throughout:

Done	Gate passed.
Done (internal)	Built and verified internally; external verification still pending.
In progress	Work under way.
Next	Approved to start after the current gate.
Not started	Planned.

Source of truth: when this PDF and the repository disagree, the repository wins. Regenerate this file with `python docs/tools/build_lifecycle_pdf.py` after updating status.

2. Lifecycle at a glance

Nine phases. Each ends with a gate that must pass before the next begins.

Phase	Name	Duration	Status
0	Legal and business foundation	1–2 months (parallel)	**In progress**
1	Requirements and threat model	3–4 weeks	**Done**
2	Architecture and design	4–6 weeks	**Done**
3	Development	4–5 months	**In progress**
4	Testing and hardening	6–8 weeks	**Not started**
5	External audits	6–8 weeks	**Not started**
6	Pilot (SECP sandbox)	2–3 months	**Not started**
7	Production launch	2–4 weeks	**Not started**
8	Operations and maintenance	Continuous	**Not started**

Total to launch: about 12–15 months. In a security-first project, rushing is the single biggest risk. Phase 0 runs in parallel with Phases 1–3, but code that depends on the legal structure waits for its gate.

Flow



3. Guiding principles

Principle	What it means in practice
Gates are not skipped.	Deadline pressure never justifies passing a gate whose criteria are not met.
Spec first, then tests, then code.	Behaviour changes start in the specification; every invariant has a named test.
No single failure loses investor money.	Not one bug, one stolen key, one dishonest insider, or one company failing.
Contracts never hold money.	PKR moves through banks; the chain records ownership and entitlements.
Reuse audited code; keep custom code small.	ERC-3643 core is reused unchanged; our guards each expose one narrow power.
Every power is time-locked or multi-signed.	72h timelock on all owners; Safes for every value-moving action.
No contract change after audit without re-audit.	No exceptions, including 'small' fixes.
Separate keys per environment.	Production keys live only on hardware (HSM/MPC, hardware wallets).
Small pilot, gradual launch.	Limits start low and rise only with evidence.

4. Phases 0–8 in detail

Objective, activities, deliverables, standards and exit gate for each phase.

Phase 0 Legal and business foundation

1–2 months (parallel) — **In progress**

Objective	Make the token legally meaningful before any code depends on the structure.
Key activities	• Choose the legal route with counsel and SECP: REIT under the REIT Regulations, or the SECP regulatory sandbox. • Agree terms with an independent trustee (e.g. CDC) who holds the property and the register. • Select the first property; verify title (Sub-Registrar, fard/PLRA, housing society NOC, encumbrance search). • Appoint a Shariah advisor; obtain two independent PBA-panel valuations. • Legal opinion on the ERC-3643 GPL-3.0 licence.
Deliverables	Legal structure memo, trustee term sheet, title report, valuation reports, Shariah opinion.
Standards	FATF R.10/R.15, AML Act 2010, SECP rules, PVARA rules as issued.
Exit gate	**Legal structure final and trustee engaged. Code that depends on it does not start before this.**

Phase 1 Requirements and threat model

3–4 weeks — **Done**

Objective	Write down what the system must do, what it must never allow, and who might attack it.
Key activities	• Functional requirements: onboarding, KYC, invest, rent payout, transfer, exit, admin flows. • Non-functional requirements: security, 99.9% uptime, p95 under 100 ms for reads, compliance. • STRIDE threat model per component, plus insider and supply-chain threats; abuse cases.
Deliverables	docs/threat-model.md (50+ threats with controls), docs/product-map.md, security-standards.md.
Standards	NIST CSF 2.0 (identify), OWASP SAMM (threat assessment).
Exit gate	**Every high risk has a named control. Passed 2026-10-08.**

Phase 2 Architecture and design

4–6 weeks — **Done**

Objective	Fix the architecture and contract behaviour on paper, where mistakes are cheapest.
Key activities	• System architecture: chain never in the read path; signing service isolated; read model + indexer. • Contract specification: every function, role, limit and invariant written in English first. • Stack decision (ADR 0001): Solidity + Foundry, ERC-3643, Besu QBFT, NestJS/Fastify, PostgreSQL, Next.js, Flutter. • Key ceremony plan and multisig signer allocation.
Deliverables	docs/contract-spec.md (v0.3, invariants I-1 to I-17), docs/decisions/0001-stack.md.
Standards	EthTrust [Q] documentation requirements, NIST SSDF (PO, PW.1).
Exit gate	**Architecture review completed; external security consultant review recommended before Phase 5.**

Phase 3 Development

4–5 months — In progress

Objective	Build the system in seven gated steps, smart contracts first because everything depends on them.
Key activities	• Step 1 Repo and CI · Step 2 Specs · Step 3 Contracts · Step 4 Local chain. • Step 5 Backend services · Step 6 Internal portals · Step 7 Investor apps and website. • Two-week sprints; every change through a pull request with two reviewers and green CI. • Tests for every invariant written together with the function, never afterwards.
Deliverables	Working system on the local chain; see the Development Flow section for per-step detail.
Standards	Per-step standards table (EthTrust, ASVS L3, MASVS L2+R, CCSS III, CIS).
Exit gate	**Feature complete; coverage at target; no open high static-analysis findings.**

Phase 4 Testing and hardening

6–8 weeks — Not started

Objective	Prove the whole system holds under attack, failure and load.
Key activities	• Formal verification of the guard contracts (Certora or Halmos); extended fuzzing campaigns. • End-to-end flows: KYC → invest → mint → rent → payout → transfer → exit. • Failure tests: bank API down, validator down, duplicate requests, indexer lag. • Load test at 5× expected traffic; internal security review; first penetration test; DR restore drill.
Deliverables	Formal verification report, test reports, pen-test report, DR drill record.
Standards	OWASP ASVS L3 verification, MASTG, CIS Benchmarks.
Exit gate	**All critical and high issues fixed and retested.**

Phase 5 External audits

6–8 weeks — Not started

Objective	Independent confirmation by two separate firms.
Key activities	• Code freeze on contracts for the audit window. • Two independent smart-contract audits, including vendored T-REX modules and findings F-01 to F-03. • Fix findings; auditors review the fix diff; publish reports. • External penetration test of APIs, portals and apps; EthTrust [Q] assessment by an auditor.
Deliverables	Two audit reports, fix-review letters, pen-test report, EthTrust assessment.
Standards	EthTrust [Q], OWASP ASVS L3, OWASP MASVS L2+R.
Exit gate	**Zero open critical or high findings. Any later contract change needs a re-audit, no exceptions.**

Phase 6 Pilot (SECP sandbox)

2–3 months | Not started

Objective	Run real money at small scale under regulatory supervision.
Key activities	• One fully let commercial property; 50–200 invited investors with per-investor caps. • Two to three full rent cycles; daily three-way reconciliation must match every day. • Bug bounty live; incident drills (key leak, pause, recovery) with timed response.
Deliverables	Pilot report to SECP, reconciliation history, incident drill records.
Standards	CCSS III operations, NIST CSF respond/recover.
Exit gate	**No money or ownership mismatch during the pilot; regulator approval to scale.**

Phase 7 Production launch

2–4 weeks | Not started

Objective	Go live with the audited code and no residual deployer power.
Key activities	• Recorded key ceremony with the auditor present; Safes created on hardware wallets. • Deploy through DeployLib; run checkHandover; verify bytecode against the audited commit. • Destroy the deployer key. After 72h: timelock sets the trustee cap; Admin Safe unpauses (tokens deploy paused). • 24/7 on-call and monitoring live; launch with low limits and raise gradually.
Deliverables	Deployment record, ceremony video, bytecode verification, go-live sign-off.
Standards	SLSA L3 provenance, CCSS III key generation, EthTrust deployment checks.
Exit gate	**Go-live sign-off by Admin Safe signers and the trustee.**

Phase 8 Operations and maintenance

Continuous | Not started

Objective	Keep the system safe, reconciled and compliant for its whole life.
Key activities	• Daily reconciliation; weekly alert review and dependency updates; monthly access review. • Quarterly key-rotation and disaster-recovery drills; pen test every 6 months; yearly red team and audit. • Upgrades only: proposal → audit → 72h timelock queue → public notice → multisig execution.
Deliverables	Operations logs, drill records, audit reports, ISO 27001 / SOC 2 evidence.
Standards	ISO 27001, SOC 2 Type II, ISO 27701, CIS Controls v8 IG3.
Exit gate	**Continuous; reviewed at every certification audit.**

5. Development flow (Steps 1–7)

Phase 3 broken into seven steps, each with its own review gate.

Step	Scope	Status	Delivered / planned
1	Repo setup, CI, stack decision	Done	Monorepo, CI (tests, Slither, gitleaks), ADR 0001, PR template.
2	Contract spec and threat model	Done	Spec v0.3 with invariants I-1 to I-17; STRIDE threat model; standards baseline.
3	Smart contracts	Done (internal)	5 guards, 2 registries, public anchor on ERC-3643 4.1.3 + T-REX 4.1.6 modules. 121 tests, 100% coverage, Slither 0, EthTrust [Q] self-assessment, deploy verified on Anvil.
4	Local chain	Done	4-validator Besu 26.9 QBFT network (portable JDK 25); deployed via DeployLib; 50/50 end-to-end checks on real blocks; validator outage and recovery tested.
5	Backend services	In progress	5a done: TypeScript workspace, validated config, redacting logger, PostgreSQL 18 with tamper-evident migrations, typed ABIs, CI job. Next: ledger, outbox, signing service + policy engine, indexer, reconciliation, mocks.
6	Internal portals	Not started	Operations, compliance and trustee portals with maker-checker; enforce offboarding order (F-02).
7	Investor apps	Not started	Website, investor web portal, verification page, Flutter app.

Step 3 results (smart contracts)

Check	Result
Tests (unit, fuzz, invariant)	**121 / 121 passing**; invariant campaign of 25,600 random calls, 0 violations
Coverage of our contracts	**100%** lines, statements, branches and functions
Static analysis	Slither 0.11.6: **0 results**; forge lint: 0 warnings; formatting enforced
Documentation	NatSpec on every external and public function
EthTrust	[Q] self-assessment against the v3 draft: all Met or N/A except one exception and one partial for the auditor
Deployment	Single DeployLib used by tests and production; deployed to Anvil and verified on-chain with cast
Contract sizes	Largest 3.7 KB of the 24 KB limit (small code is easier to audit)
Step 4: real network	Besu 26.9, 4 validators: **50 / 50 end-to-end checks**; QBFT kept producing blocks with one validator down

> Internal results only. Formal verification and two external audits are required before mainnet.

6. Smart-contract lifecycle

The path every contract change follows, from idea to production and beyond.

#	Stage	What happens	Evidence
1	Specify	Behaviour, roles, limits and invariants written in docs/contract-spec.md.	Spec diff in the PR
2	Test first	Unit, fuzz and invariant tests for every new rule.	Named tests per invariant
3	Implement	Smallest possible code; reuse audited libraries; checks-effects-interactions; events before calls.	Code review by a senior Solidity reviewer
4	Analyse	forge fmt, forge lint, Slither; 100% coverage target.	CI green
5	Verify formally	Core invariants proven with Certora or Halmos.	Verification report
6	Freeze and audit	Code freeze; two independent audits; fix review.	Published reports
7	Deploy	Only through script/DeployLib.sol; checkHandover asserts I-8 and I-9.	Deployment record
8	Verify bytecode	Deployed bytecode matched to the audited commit; deployer key destroyed.	Verification log
9	Go live	Timelock sets the trustee cap after 72h; Admin Safe unpauses (tokens deploy paused).	Timelock operation IDs
10	Operate and upgrade	Upgrades only via proposal → audit → 72h timelock → public notice → multisig.	Change log

Deployment hand-over checklist (enforced by DeployLib.checkHandover)

- Every owner is the 72h TimelockController: token, registries, compliance, factory, both implementation authorities, both modules, all guards.
- Deployer has no timelock admin or proposer role; Trustee Safe holds the canceller role.
- Only the four guards are token agents; the timelock is never a token agent.
- Claim issuer managed by the manager key, not the deployer; claim signer registered.
- Both compliance modules bound; token still paused until go-live.

7. Engineering workflow

Environments, branching, pull requests and the CI pipeline.

Environments

Environment	Chain	Keys	Data
Local	Anvil (quick) and 4-validator Besu (chain/)	Generated dev keys, git-ignored	Synthetic
Dev	Private Besu	Software keys, dev-only	Synthetic
Staging	Besu, production-like	Separate HSM partition	Anonymised
Production	Besu, 4 organisations + public anchor	HSM/MPC, hardware-wallet Safes	Real; never copied down

Branching and pull requests

- **main** is protected: pull request required, two approvals, CI required, signed commits.
- One feature per branch; small pull requests; the PR template carries the security definition of done.
- No new dependency without written justification; dependencies pinned to exact versions or tags.
- No secrets, keys or personal data in code, logs or fixtures; .env files are never committed.

Security definition of done (every pull request)

	Requirement
☐	Spec or ADR updated if behaviour changed
☐	Threat model updated for any new asset, flow or trust boundary
☐	Tests written, including failure and abuse cases
☐	CI green: tests, coverage, static analysis, secret scan, dependency scan
☐	No unjustified new dependency
☐	No secrets or personal data
☐	Two approvals (contracts: one senior Solidity reviewer)
☐	Signed commits

CI pipeline

Stage	Tooling	Fails the build when
Secret scan	gitleaks	Any secret pattern is found
Format and lint	forge fmt --check, forge lint	Formatting differs or a lint fires
Build and test	forge build --sizes, forge test	Any test fails or a contract exceeds size limits
Coverage	forge coverage	Coverage falls below target
Static analysis	Slither	Any high-severity finding

8. Security standards by step

A gate cannot pass until its standards are met and the evidence is in the repository.

Step / phase	Standards that must be met at the gate
1 Repo and CI	NIST SSDF (PO, PS), OpenSSF Scorecard, secret scanning
2 Specs	Complete STRIDE threat model; NIST CSF risk mapping
3 Contracts	EthTrust [Q] self-assessment, OWASP SCSVS, Smart Contract Top 10, 100% branch coverage on guards, invariants passing, Slither clean
4 Chain	CIS Benchmarks on nodes, TLS between nodes, node allow-list
5 Backend	OWASP ASVS L3, API Security Top 10, NIST 800-63B, CCSS III design for the signing service
6 Internal portals	OWASP ASVS L3; AAL3 staff authentication (FIDO2 hardware keys)
7 Mobile app	OWASP MASVS L2 + RESILIENCE
Pre-launch	Two contract audits, external pen test, SLSA L3, CIS IG3, ISO 27001 and SOC 2 programmes started

Full baseline

Area	Standard	Target
Smart contracts	EEA EthTrust Security Levels, OWASP SCSVS	Level [Q]
Web and APIs	OWASP ASVS 5.0, API Security Top 10	Level 3
Authentication	NIST SP 800-63B	AAL2 investors, AAL3 staff
Mobile	OWASP MASVS 2	L2 + RESILIENCE
Keys and custody	CCSS, FIPS 140-3, NIST SP 800-57	CCSS III, HSM Level 3
Supply chain	NIST SSDF, SLSA, OpenSSF Scorecard, OWASP SAMM	SLSA Build L3
Infrastructure	CIS Benchmarks, CIS Controls v8	IG3
Organisation	ISO 27001, SOC 2 Type II, ISO 27701, NIST CSF 2.0	Certification before public launch
Compliance	FATF, AML Act 2010, SECP/PVARA, PECA 2016	Mandatory

9. What gets built

Websites, portals, apps and services (full detail in docs/product-map.md).

#	Product	Users	Phase
1	Public website	Everyone	Pilot
2	Investor web portal	Investors	Pilot
3	Investor mobile app (Android, iOS)	Investors	Pilot
4	Public verification page	Anyone	Pilot
5	Operations / admin portal	Operations staff	Pilot
6	Compliance portal	Compliance officer	Pilot
7	Trustee portal	Trustee officers	Pilot
8	Multisig signing console	Safe signers	Pilot
9	Property sponsor portal	Property owners	Later
10	Secondary market	Investors	After regulatory approval

Backend services

API gateway · Auth (passkeys, device binding) · Ledger (double-entry, append-only, hash-chained) · Signing service (HSM/MPC, policy engine) · Indexer · Reconciliation (chain vs ledger vs bank) · KYC (NADRA Verisys, liveness, sanctions/PEP) · Payments (bank, Raast) · Notifications · Document store · Anchor job · Monitoring.

Blockchain layer

ERC-3643 token suite with our guard contracts (built), private Besu QBFT network with four validators run by separate organisations (Step 4), and an hourly public-chain anchor (built; network choice pending).

10. Team and roles

Role	Count	Responsibility
Senior Solidity / blockchain engineer	1–2	Contracts, chain, audits liaison
Backend engineers	2	Services, ledger, signing service, integrations
Flutter / web developers	1–2	Investor apps, website, portals
DevOps / security engineer	1	Infrastructure, CI/CD, monitoring, key management
QA engineer	1	Test plans, end-to-end and failure testing
Product manager	1	Requirements, gates, stakeholder alignment
Compliance officer	1	KYC/AML, FMU reporting, regulator liaison
External: auditors, pen testers, lawyer, Shariah advisor, trustee	Contract	Independent assurance and legal structure

11. Findings and top risks

Found during Step 3. All three are in vendored code; each has a tested mitigation.

ID	Issue	Mitigation	Status
F-01	ONCHAINID claim revocation can be bypassed by re-encoding the old signature; a revoked investor becomes verified again.	Never rely on revocation. Offboarding: freeze immediately → move or redeem tokens → delete identity through the timelock.	Mitigated, tested
F-02	MaxBalanceModule strands tokens if a holder's identity is deleted or updated.	Same offboarding order; never update a holding wallet's identity; admin portal enforces; invariant I-17.	Mitigated, tested
F-03	ONCHAINID claim signatures do not include chainid (cross-chain replay).	One claim-signer key per chain.	Mitigated by design

Top risks to address first

Risk	Why it matters	Planned control
Key compromise (K-1 to K-3)	Whoever holds keys controls ownership records	HSM/MPC signing service with policy engine, multisig, rotation drills
Contract bugs (SC-1, SC-2)	Could mint or move tokens	Tests, formal verification, two audits
Payout redirection (M-1)	Most common real-world fraud	IBAN title match to CNIC, 72h cooling-off on bank changes
SIM swap (API-2)	Common in Pakistan	Passkeys or authenticator app from the first release

12. Operations cadence

Frequency	Activity
Daily	Three-way reconciliation (chain, ledger, bank); payouts freeze on mismatch
Weekly	Alert review; dependency updates
Monthly	Access review: who holds what, and is it still needed
Quarterly	Key-rotation drill; disaster-recovery restore drill
Every 6 months	External penetration test; standards baseline review
Yearly	Red-team exercise; full security audit; certification audits (ISO 27001, SOC 2)
Every upgrade	Proposal → audit → 72h timelock → public notice → multisig execution

13. Open decisions and next actions

Decisions for the owner

#	Decision	Needed by
1	ERC-3643 is GPL-3.0: legal opinion on our deployment and distribution model	Before mainnet
2	Public anchor chain: Ethereum mainnet (most trusted, costly) or an L2 such as Base or Polygon (cheap)	Step 5
3	Auditor rulings: single-key exception (pauser, registrar, anchor key); token-address validation in registries	Phase 5
4	Retail investment limits	Before pilot

Next actions

#	Action	Owner
1	Step 5b onwards: ledger, outbox, signing service, indexer, reconciliation (PostgreSQL 18)	Engineering
2	GitHub branch protection on main, Dependabot alerts, secret scanning	Repository owner
3	Report F-01 to the ONCHAINID maintainers (responsible disclosure)	Engineering
4	Shortlist two audit firms and a formal-verification provider	Founders
5	Continue Phase 0: legal route, trustee, first property title checks	Founders + counsel

Appendix: Glossary

Term	Meaning
ERC-3643	Ethereum standard for permissioned security tokens: only verified identities can hold or receive.
ONCHAINID	On-chain identity contract per investor, carrying KYC and AML claims signed by a trusted issuer.
Guard contract	Our small contract that holds exactly one token power (mint, pause, freeze, recovery, register) with limits.
TimelockController	Contract that delays privileged actions (72h) so they are visible and can be cancelled.
Safe (multisig)	Wallet that needs several signers (e.g. 3-of-5) to approve a transaction.
Besu QBFT	Permissioned Ethereum client with a consensus that gives immediate finality (no re-orgs).
State anchor	Hourly hash of the private chain written to a public chain, making history rewrites detectable.
Merkle root	Single hash committing to every investor's rent entitlement; each investor can verify their own share.
Maker-checker	One person prepares an action, a different person approves it.
HSM / MPC	Hardware security module / multi-party computation: ways to use keys without exposing them.
Trustee register	The trustee's official record of units; total token supply can never exceed it.
KYC / AML	Know Your Customer identity checks / Anti-Money Laundering controls.
SECP, PVARA, FMU, CDC	Securities regulator; virtual-assets regulator; Financial Monitoring Unit; Central Depository Company.